NOTE

You'll often see models such as ACL, RBAC, and ABAC described as access control models. That's the traditional term, particularly in security and operating system contexts. In this book, we refer to them as authorization models to emphasize their role in determining which actions are allowed—especially in the context of externalized, policy-driven systems. The underlying concepts remain the same; the shift in terminology reflects a broader view of how modern systems make access decisions.

5.1 Access Control Lists (ACL)

Access Control Lists are one of the earliest and most straightforward methods for managing authorization. They attach permissions directly to resources, specifying which users or groups can perform certain actions. This approach is simple and intuitive, and remains widely used in file systems, network shares, and legacy applications. But as organizations grow and access needs become more dynamic, the limitations of ACLs quickly become evident.

To see how ACLs work in practice, consider a familiar scenario. At ACME Corp, Alice manages the marketing team and maintains a shared folder of campaign plans on the company's internal file server. She wants her team to be able to read the documents but not edit them. Meanwhile, Bob, a fellow manager in Product, is collaborating with marketing on a new launch and needs both read and write access to the campaign plans.

To manage this strategy, Alice creates the folder and sets its permissions. She doesn't know it, but she's created an Access Control List (ACL):

- Alice: read, write
- Marketing team: read
- Bob: read, write
- Everyone else: no access